

Legislation & Frameworks

The laws every Australian network must obey, and the frameworks that turn "be secure" into a real to-do list. We map all five — through the eyes of a Melbourne learner-driver app called Clutch.

What this key knowledge covers

This summary distils everything you need for **KK13 — Legislation & Frameworks** in Cyber Security. Work through the explanations, then use the worked good-vs-weak answers to see exactly how marks are won and lost. Tick off the revision checklist at the end before a SAC or exam.

Study summary

Why a network has to obey the law

In KK06–KK12 you learned how attacks happen and how to stop them. KK13 asks a different question: *who says you have to?* The answer is the law — plus the frameworks that show you exactly how.

Clutch is a Melbourne start-up app that helps learner drivers log their 120 hours, book lessons, and track progress. It has grown to about **40,000 users** aged 16–25 across Victoria.

To do its job, Clutch stores: names, dates of birth, learner-permit numbers, GPS logs of every practice drive, payment details — and, for some users, a **medical fitness-to-drive declaration** (epilepsy, vision, etc.). That single mix of data is enough to pull Clutch under *three different privacy laws* at once. This module shows you why.

Think of it like the road rules Clutch's own users have to follow. A learner doesn't get to invent their own speed limit — it's set by law, and breaking it has consequences. Networks are the same. If Clutch leaks 40,000 teenagers' data, "we didn't realise" is not a defence. **The Notifiable Data Breaches (NDB) scheme** can compel them to tell every affected user and the regulator, and the regulator can investigate and fine.

Laws (Privacy Act, PDP Act, Health Records Act) are like the road rules: mandatory, enforceable, and you can be penalised for breaking them. They tell you *what* you must achieve.

Frameworks (Essential Eight, ISM) are like the structured lessons a learner takes: not a law in themselves, but the practical, step-by-step way to actually become a safe driver. They tell you *how* to get there.

Laws vs frameworks — the distinction examiners love

A surprising number of marks are lost because students call the Essential Eight "a law" or the Privacy Act "a guideline". They are fundamentally different, and KK13 lists both deliberately.

The laws say "*protect the data*" but don't spell out the technical steps. The Essential Eight and ISM *are* those steps. So following a framework is one of the clearest ways to **prove** you met a law's security obligation (APP 11). They're two halves of the same answer.

Privacy Act 1988 (Cwlth) — the Australian Privacy Principles

The big federal one. It runs the **13 Australian Privacy Principles (APPs)** and applies right across Australia to most private businesses (with turnover over \$3M) and Australian Government agencies.

Because Clutch is a **private company operating nationally**, the Privacy Act is its baseline. The 13 APPs cover the whole life-cycle of personal information — from collecting it openly, to using it only for the purpose you collected it for, to securing it, to letting people see and correct their own data.

- A plain-English privacy policy in the app's sign-up flow, not buried in legalese.
- Says GPS logs are kept and why (lesson verification).
- GPS logs collected to verify driving hours *cannot* be sold to an insurer.
- That would be using data outside its **primary purpose**.
- Clutch backs up to a US cloud region — APP 8 still binds Clutch.
- It must take reasonable steps to ensure the US provider protects the data.
- This is where the Essential Eight & ISM plug in — they're *how* Clutch meets APP 11.
- Encryption, MFA, patching, backups = "reasonable steps".

Bolted onto the Privacy Act, the **Notifiable Data Breaches (NDB) scheme** means that if Clutch suffers a breach *likely to cause serious harm*, it must notify **both** the affected users **and** the Office of the Australian Information Commissioner (OAIC) as soon as practicable. Hiding a breach is itself a breach. This is the single most exam-relevant consequence of the Act.

Privacy and Data Protection Act 2014 (Vic) — the IPPs

Victoria's own privacy law. It runs the **10 Information Privacy Principles (IPPs)** and applies to the **Victorian public sector** — state government departments, councils, Victoria Police, public schools, and the contractors who handle their data.

So when does a private app like Clutch touch the PDP Act? The moment it **works for a Victorian government body**. Imagine the Department of Transport hires Clutch to run an official "Learner Hours" verification service. Clutch is now handling personal information *on behalf of* a Victorian public-sector agency — so the IPPs apply to that data, *on top of* the Privacy Act for everything else.

The IPPs are deliberately very similar to the APPs (collection, use, security, access). Think of them as the **state-level version** of the same idea — like how you can hold a national passport *and* a Victorian driver's licence. Different issuer, overlapping coverage, both valid at once. The key difference is *who* they cover: APPs = private sector & federal; IPPs = Victorian public sector.

Health Records Act 2001 (Vic) — the HPPs

Health information is the most sensitive personal data there is, so Victoria gives it its own law: the **11 Health Privacy Principles (HPPs)**. This Act covers health information held by **both** the public **and** the private sector in Victoria.

Remember Clutch's **fitness-to-drive medical declarations** (epilepsy, vision conditions, medications affecting driving)? That is health information. The instant Clutch stores it, the Health Records Act switches on — regardless of whether Clutch has any government contract at all. This is why the same app can sit under three laws at once.

A general user with no medical info → governed mainly by the **Privacy Act (APPs)**.

A user who declares epilepsy for fitness-to-drive → that health record is also governed by the **Health Records Act (HPPs)**.

If the Dept of Transport contracts Clutch to verify hours → that slice of data also falls under the **PDP Act (IPPs)**. One app, three regimes, depending on the data and the relationship.

The three privacy regimes, side by side

Examiners frequently ask you to *compare* or *distinguish* these three. The differences live in just three columns: jurisdiction, who it covers, and its principle set.

APP = **A**ll of Australia (federal). **IPP** = **I**nside Victorian government. **HPP** = **H**ealth, anywhere in Victoria. Three letters, three triggers.

Which law applies? — the Compliance Map

This is the skill the exam tests: given a scenario, name the law(s) that apply and *justify why*. Flip the switches to change what data Clutch handles and who it works for. Watch the shields light up — and read the verdict that explains each one.

The Essential Eight — turning "be secure" into eight jobs

Published by the **Australian Signals Directorate (ASD)**, the Essential Eight is a set of eight baseline mitigation strategies. It's not a law, but it's the most practical answer to the security duty in APP 11 / HPP 4 / IPP 4. Each strategy has a **maturity level (0-3)** — raise Clutch's maturity and watch its resilience climb.

Maturity Level 0 is a fresh learner who's never driven. ML1 is supervised L-plates. ML2 is solo P-plates. ML3 is a confident, experienced driver. The Essential Eight gives Clutch the same staged pathway — you don't jump to perfect overnight; you mature each control step by step.

The ISM — the deep networking rulebook

The **Information Security Manual (ISM)**, also from the ASD, is a far more detailed cyber-security framework. KK13 specifically points you at its **networking guidelines** — how to design, segment and harden a network.

If the Essential Eight is the "eight big habits", the ISM is the **full driving handbook** — hundreds of specific controls covering network segmentation, gateways, cryptography standards, logging and monitoring. It's primarily mandatory for federal government systems, but private organisations like Clutch use it as a gold-standard reference, especially the parts on isolating sensitive systems.

Essential Eight — short, prioritised, "do these eight first". A great starting baseline.

ISM — comprehensive, granular, the complete reference. Its networking guidelines tell Clutch *how* to segment its learner database away from its public web servers so one breach can't reach everything.

Following ISM networking guidance, Clutch puts its 40,000 user records on an **isolated, segmented subnet** behind a firewall, separate from the public-facing booking website. If an attacker compromises the website, network segmentation stops them reaching the sensitive database — exactly the "defence in depth" the ISM is built around.

Exam technique for legislation questions

These questions reward precision: the exact name of the law, the exact principle, and a clear link to the scenario. Tap a command word to see what the examiner actually wants.

Name the law and its principle set (e.g. "Privacy Act 1988 — APP 11"). **Anchor** it to the scenario data (e.g. "because Clutch stores 40,000 users' personal information"). **Justify** the link (e.g. "so it must take reasonable steps to secure that data"). Name → Anchor → Justify wins full marks.

VCE practice questions

Five exam-style questions, 20 marks total. Try each one *before* revealing the responses. Compare the weak and strong answers, read the marking guide, then self-mark — your score feeds the dock in the corner.

Legislation and frameworks are both about cyber security and keeping data safe. The Essential Eight is a law that organisations have to follow to be secure.

Legislation (e.g. the Privacy Act 1988) is made by Parliament and is **legally binding** — it sets out **what** outcomes an organisation must achieve and can be enforced with penalties. A framework such as the Essential Eight is **guidance** issued by the ASD that recommends **how** to achieve security; it is best practice rather than law and carries no direct penalty of its own.

- * 1 mark: legislation is mandatory/legally binding ('what')
- * 1 mark: framework is recommended guidance/best practice ('how')
- * Full marks need the contrast made explicit, not two separate definitions

The Privacy and Data Protection Act applies because Clutch is in Victoria. Also the Privacy Act applies because they store personal data like names.

Privacy Act 1988 (Cwlth) applies because Clutch is a national private business collecting **personal information** (names, DOB, permit numbers, GPS logs) from 40,000 users, so it must comply with the 13 APPs. **Health Records Act 2001 (Vic)** also applies because the fitness-to-drive medical declarations are **health information** held in Victoria, which is governed by the Health Privacy Principles. Each law is triggered by a different category of data Clutch holds.

- * 1 mark each: correctly name Privacy Act 1988 and Health Records Act 2001
- * 1 mark each: justify with the matching data type (personal info → APPs; health info → HPPs)
- * No credit for PDP Act here — there is no government contract in this scenario

Clutch has to tell people there was a hack so they can change their passwords. They might get in trouble for it.

□ KK13 in one glance

Federal · 13 APPs · private sector & federal gov · personal info · regulator OAIC · NDB scheme.

Victorian · 10 IPPs · Vic public sector & contractors · regulator OVIC.

Victorian · 11 HPPs · health info, public OR private · regulator HCC.

ASD framework · 8 baseline strategies · maturity levels 0–3 · the "how" for security duties.

ASD framework · detailed networking guidelines · segmentation, gateways, crypto · gold-standard reference.

Laws = mandatory "what", made by Parliament. Frameworks = recommended "how", made by ASD.

Name the law/principle → Anchor to scenario data → Justify the obligation.

APP = All Australia · IPP = Inside Vic gov · HPP = Health anywhere in Vic.

Common traps & misconceptions

Exam trap

⚠ Exam trap — "Victorian app = Victorian law" Being based in Melbourne does *not* automatically put a private business under the PDP Act. A private company is governed by the **federal Privacy Act**. The PDP Act only reaches it through a **public-sector relationship** (a government contract). State the trigger, don't assume geography.

Exam trap

⚠ Exam trap — "health info needs a doctor" Health information isn't only what a hospital holds. A fitness app, a gym, an employer's first-aid log, or a learner-driver app collecting a medical declaration *all* hold health information. The HPPs follow the *data*, not the building.

Exam trap

⚠ Exam trap — naming one law when two or three apply Scenarios are designed to overlap. If the data includes a health record *and* there's a government contract, you must name **all** applicable laws and justify each. "The Privacy Act applies" alone would forfeit the marks for the HPPs and IPPs.

Exam trap

⚠ Exam trap — listing only "the famous three" Students often name only MFA, backups and patching. The full eight also includes **application control, patching operating systems, restricting admin privileges, configuring macro settings, and user application hardening**. If a question says "describe Essential Eight strategies (4 marks)", you need four *distinct* ones.

How to answer exam questions

Read the **command word** first — it sets how much to write. *State/Identify* wants a word or phrase; *Describe* wants features; *Explain* wants reasons and links; *Justify/Evaluate* wants a judgement backed by evidence. Always pull in the **scenario detail** rather than answering in the abstract. The examples below contrast a weak response with a strong one for the same question.

Q1. Distinguish · 2 marks

Distinguish between legislation and a cyber-security framework such as the Essential Eight.

✗ A weak answer

How NOT to answer Legislation and frameworks are both about cyber security and keeping data safe. The Essential Eight is a law that organisations have to follow to be secure. Calls the Essential Eight a law (it isn't), and never states the actual distinction. 0–1 marks.

✓ A strong answer

Full-mark response Legislation (e.g. the Privacy Act 1988) is made by Parliament and is **legally binding** — it sets out **what** outcomes an organisation must achieve and can be enforced with penalties. A framework such as the Essential Eight is **guidance** issued by the ASD that recommends **how** to achieve security; it is best practice rather than law and carries no direct penalty of its own.

How the marks are awarded

- 1 mark: legislation is mandatory/legally binding ('what')
- 1 mark: framework is recommended guidance/best practice ('how')
- Full marks need the contrast made explicit, not two separate definitions

Q2. Identify · 4 marks

+ Justify Clutch stores names, dates of birth, learner-permit numbers and GPS driving logs for 40,000 users. For some users it also stores a fitness-to-drive medical declaration. Identify two laws that apply to Clutch and justify why each applies. Hint: think about the type of data, not just where Clutch is based.

✗ A weak answer

How NOT to answer The Privacy and Data Protection Act applies because Clutch is in Victoria. Also the Privacy Act applies because they store personal data like names. Misapplies the PDP Act (geography ≠ public-sector trigger) and only really names one correct regime. The health data is missed entirely. ~1 mark.

✓ A strong answer

Full-mark response **Privacy Act 1988 (Cwlth)** applies because Clutch is a national private business collecting **personal information** (names, DOB, permit numbers, GPS logs) from 40,000 users, so it must comply with the 13 APPs. **Health Records Act 2001 (Vic)** also applies because the fitness-to-drive medical declarations are **health information** held in Victoria, which is governed by the Health Privacy Principles. Each law is triggered by a different category of data Clutch holds.

How the marks are awarded

- 1 mark each: correctly name Privacy Act 1988 and Health Records Act 2001
- 1 mark each: justify with the matching data type (personal info APPs; health info HPPs)
- No credit for PDP Act here — there is no government contract in this scenario

Q3. Explain · 4 marks

Clutch's user database is breached and 40,000 records are exposed. Explain the Notifiable Data Breaches (NDB) scheme and what Clutch is required to do.

✗ A weak answer

How NOT to answer Clutch has to tell people there was a hack so they can change their passwords. They might get in trouble for it. Vague, no mention of the scheme's legal basis, the 'serious harm' test, or notifying the regulator. ~1 mark.

✓ A strong answer

Full-mark response The NDB scheme operates under the **Privacy Act 1988** and applies to data breaches **likely to result in serious harm** to the individuals affected. Because the exposed records contain sensitive personal (and health) data, this threshold is met. Clutch must, **as soon as practicable**, notify **both** the affected users **and** the Office of the Australian Information Commissioner (OAIC), describing the breach, the information involved and the steps users should take. Failing to report would itself breach the Act.

How the marks are awarded

- 1 mark: NDB sits under the Privacy Act 1988
- 1 mark: applies to breaches likely to cause serious harm
- 1 mark: must notify affected individuals
- 1 mark: must also notify the OAIC (regulator) as soon as practicable

Q4. Describe · 4 marks

Describe two Essential Eight strategies Clutch could implement, and for each, explain how it helps Clutch meet its security obligation under APP 11.

✗ A weak answer

How NOT to answer Clutch should use multi-factor authentication and back up their data. This makes them more secure and follows the Essential Eight. Names two strategies but doesn't describe how each works or link to APP 11 specifically. ~2 marks.

✓ A strong answer

Full-mark response **Multi-factor authentication (MFA)**: requiring a second factor (e.g. a phone code) means a stolen password alone can't unlock an account, directly reducing unauthorised access — exactly the 'reasonable steps' APP 11 demands. **Regular backups**: keeping tested, isolated backups means that if ransomware encrypts the user database, Clutch can restore the 40,000 records rather than lose them, protecting the data from loss as APP 11 requires. Both are concrete ways Clutch proves it took reasonable security steps.

How the marks are awarded

- 1 mark each: clearly describe two DISTINCT Essential Eight strategies
- 1 mark each: link each to meeting APP 11's 'reasonable steps to secure data' duty
- Naming alone (no description or link) caps the answer at 2 marks